

CHECKLIST KESIAPAN KEAMANAN DATA QRUP1 UNTUK SKALA NASIONAL

Dokumen kerja untuk persiapan platform monitoring pendidikan nasional. Fokus: perlindungan data peserta didik, keamanan cloud, tata kelola, kepatuhan, dan kesiapan operasional.

1. TATA KELOLA & KEPATUHAN

- Petakan seluruh data yang dikumpulkan: identitas siswa, orang tua/wali, sekolah, kelas, aktivitas, hasil monitoring, dan data lain yang relevan.
- Tentukan tujuan pemrosesan setiap jenis data dan dokumentasikan dasar pemrosesannya.
- Susun Privacy Policy, Kebijakan Pelindungan Data Pribadi, dan prosedur persetujuan/pemberitahuan kepada pihak yang relevan.
- Pastikan peran dan tanggung jawab pengendali/prosesor data jelas dalam setiap kerja sama dengan sekolah atau instansi pemerintah.
- Siapkan mekanisme pemenuhan hak subjek data: akses, koreksi, penghapusan sesuai ketentuan, serta penanganan permintaan lainnya.
- Siapkan perjanjian pemrosesan data (DPA) dan klausul keamanan dengan sekolah, kementerian, vendor, dan penyedia cloud.
- Evaluasi kewajiban terkait UU PDP, PP 71/2019, dan ketentuan PSE yang berlaku sebelum peluncuran nasional.

2. ARSITEKTUR & KEAMANAN CLOUD AWS

- Pisahkan environment Production, Staging/UAT, dan Development.
- Gunakan prinsip least privilege dengan IAM dan role-based access control.
- Aktifkan MFA untuk akun administrator dan akses istimewa.
- Gunakan enkripsi data saat transit (TLS) dan saat tersimpan; kelola kunci secara terkontrol.
- Pisahkan database dari internet publik dan gunakan private subnet/security groups sesuai kebutuhan.
- Gunakan logging dan monitoring terpusat untuk aktivitas admin, database, API, dan infrastruktur.
- Gunakan WAF, proteksi DDoS, rate limiting, dan API security.
- Gunakan backup otomatis, point-in-time recovery, serta salinan backup yang terisolasi.
- Siapkan disaster recovery dengan target RTO/RPO yang disepakati.

3. KEAMANAN APLIKASI QRUP1

- Lakukan secure software development lifecycle (SSDLC).
- Code review dan vulnerability scanning wajib menjadi bagian dari proses deployment.
- Lakukan penetration test dan vulnerability assessment secara berkala.
- Amankan API dengan autentikasi, otorisasi, token management, rate limiting, dan validasi input.
- Gunakan OWASP sebagai baseline keamanan aplikasi web/mobile/API.
- Jangan menyimpan password dalam bentuk plaintext; gunakan password hashing yang kuat.
- Lindungi secret/API key menggunakan secret manager, bukan source code.
- Implementasikan session management, device/session control, dan logout/invalidation.

4. DATA PESERTA DIDIK

- Minimalkan pengumpulan data: hanya data yang benar-benar diperlukan.
- Pisahkan data identitas dengan data aktivitas jika arsitektur memungkinkan.
- Gunakan pseudonymization/tokenisasi untuk kebutuhan analitik bila memungkinkan.
- Tetapkan klasifikasi data: publik, internal, rahasia, dan sangat sensitif sesuai kebijakan internal.
- Tentukan retention period dan mekanisme secure deletion.
- Batasi akses berdasarkan kebutuhan pekerjaan dan sekolah/wilayah/instansi.
- Audit seluruh akses terhadap data siswa.

5. INCIDENT RESPONSE & PELAPORAN

- Buat Incident Response Plan dan tim penanganan insiden.
- Definisikan severity level dan jalur eskalasi.
- Siapkan prosedur containment, investigation, eradication, recovery, dan post-incident review.
- Siapkan prosedur notifikasi apabila terjadi kegagalan perlindungan data pribadi sesuai kewajiban hukum yang berlaku.
- Simpan log yang cukup untuk investigasi forensik dan tetapkan masa retensinya.
- Lakukan simulasi insiden minimal secara berkala.

6. SDM & AKSES INTERNAL

- Tetapkan Security Officer/Information Security Manager dan PIC PDP/DPO bila diwajibkan atau diperlukan berdasarkan skala dan risiko pemrosesan.
- Lakukan background/access review sesuai kebutuhan dan hukum yang berlaku.
- Training keamanan dan PDP untuk seluruh staf.
- Gunakan onboarding/offboarding checklist agar akses karyawan langsung diberikan dan dicabut sesuai kewenangan.
- Lakukan access review berkala untuk akun privileged.

7. AUDIT & SERTIFIKASI

- Bangun Information Security Management System (ISMS).
- Targetkan ISO/IEC 27001 sebagai kerangka sertifikasi keamanan informasi.
- Pertimbangkan ISO/IEC 27701 untuk privacy information management.
- Lakukan audit internal dan risk assessment secara berkala.
- Dokumentasikan seluruh kebijakan, SOP, risk register, asset register, dan bukti kontrol.

8. DOKUMEN YANG SEBAIKNYA SUDAH TERSEDIA

- Data Inventory & Data Flow Diagram
- Data Classification Policy
- Privacy Policy & Privacy Notice
- Personal Data Protection Policy
- Information Security Policy
- Access Control Policy
- Encryption & Key Management Policy

- Backup & Disaster Recovery Policy
- Incident Response Plan
- Vulnerability & Patch Management SOP
- Secure SDLC / Change Management SOP
- Vendor & Cloud Security Assessment
- Data Retention & Secure Deletion Policy
- Business Continuity Plan
- Risk Register & Security Risk Assessment
- Perjanjian pemrosesan data / DPA

9. TARGET MINIMUM SEBELUM ROLLOUT NASIONAL

- 100% data flow terdokumentasi.
- 100% akun privileged menggunakan MFA.
- Enkripsi data sensitif saat transit dan tersimpan.
- Logging dan monitoring aktif serta dapat diaudit.
- Backup dan disaster recovery sudah diuji.
- Penetration test sebelum go-live dan remediation atas temuan kritis.
- Incident Response Plan sudah diuji melalui tabletop exercise.
- Kontrak vendor/cloud memiliki klausul keamanan dan perlindungan data.
- Risk assessment dan DPIA/penilaian dampak perlindungan data dilakukan untuk pemrosesan berisiko tinggi bila diwajibkan/berdasarkan kebutuhan.
- Legal/compliance review sebelum kontrak nasional dan sebelum perluasan skala.

10. REKOMENDASI ARSITEKTUR KESIAPAN NASIONAL

AWS tetap dapat digunakan sebagai infrastruktur cloud. Fokus utama bukan harus memiliki server fisik sendiri, melainkan memastikan lokasi/transfer data, kontrak, konfigurasi keamanan, tata kelola, dan kontrol akses memenuhi ketentuan Indonesia serta persyaratan instansi pemerintah yang bekerja sama.

Lapisan	Kontrol utama
Aplikasi	Secure SDLC, OWASP, API security, pentest
Identitas	IAM, RBAC, MFA, privileged access management
Data	Encryption, tokenisasi/pseudonymization, retention
Cloud	Network segmentation, WAF, logging, backup, DR
Operasional	SOC/monitoring, incident response, patching
Governance	UU PDP, PSE, kontrak/DPA, risk assessment
Audit	ISO 27001, ISO 27701, audit internal/eksternal

Catatan penting: checklist ini adalah kerangka kesiapan, bukan opini hukum. Untuk rollout nasional, lakukan legal review khusus terhadap klasifikasi data, status QRUPI sebagai PSE, peran para pihak, lokasi/transfer data, dan persyaratan kontrak instansi pemerintah.